R316- METHODOLOGIE PENTEST

BUT 2 R&T
(GROUPE 1)

UNIVERSITÉ SORBONNE PARIS NORD

Réaliser par :
- Arol Tindom

Encadré par:
- Benaissa

2025 - 2026

TABLES DES MATIÈRES

1. **Introduction**
2. **Contexte**
    - 2.1 Livrables attendus
3. **Méthodologie**
    - 3.1 Identification du premier ingrédient
    - 3.2 Identification du deuxième ingrédient
    - 3.3 Identification du dernier ingrédient
4. **Conclusion**

1. Introduction

Ce rapport présente l'analyse de la machine virtuelle **Pickle Rick**, hébergée sur la plateforme TryHackMe. Le challenge consiste à identifier et récupérer trois ingrédients nécessaires pour permettre à Rick de retrouver sa forme humaine. L'objectif de cette mission est d'évaluer la sécurité du serveur web et d'exploiter les vulnérabilités présentes pour accéder aux informations sensibles. Une approche méthodique a été suivie tout au long de l'exercice, comprenant plusieurs étapes de reconnaissance, d'énumération, d'exploitation et de post-exploitation.

2. Contexte

Ce challenge fait partie d'un exercice pratique de pentesting dans lequel nous avons appliqué les compétences acquises pour tester la sécurité d'un serveur web. L'exercice nous a permis de découvrir plusieurs failles, tout en mettant en pratique des outils et techniques courants dans le domaine du pentesting.

2.1 Livrables attendus

À l'issue de cette mission, les livrables suivants ont été générés :

- Un rapport technique détaillant la méthodologie suivie, les commandes utilisées, et les preuves visuelles à l'appui.
- Une analyse approfondie des vulnérabilités identifiées.
- Une conclusion résumant les résultats obtenus, notamment la découverte des trois ingrédients secrets nécessaires à la transformation de Rick.

3. Méthodologie

3.1 Identification du premier ingrédient

Dans cette première phase, l'objectif est d'examiner les ports accessibles sur la machine cible (10.10.212.100) afin d'identifier les services actifs. Cela permet de localiser les potentielles vulnérabilités et les points d'entrée qui pourront être exploités dans les étapes suivantes.

Pour réaliser cette analyse, nous avons utilisé la commande suivante :

sudo nmap -sS -T5 10.10.212.100

Voici la signification des éléments de cette commande :

- **sudo** : permet d'exécuter la commande avec des droits élevés, nécessaires pour un scan complet

- **nmap** : outil permettant de détecter les ports ouverts et d'identifier les services qui y sont associés

- **-sS** : active un scan SYN qui permet de détecter discrètement les ports ouverts sans établir une connexion complète avec le service

- -T5 : spécifie un mode de timing rapide pour accélérer le processus de scan tout en générant davantage de trafic réseau

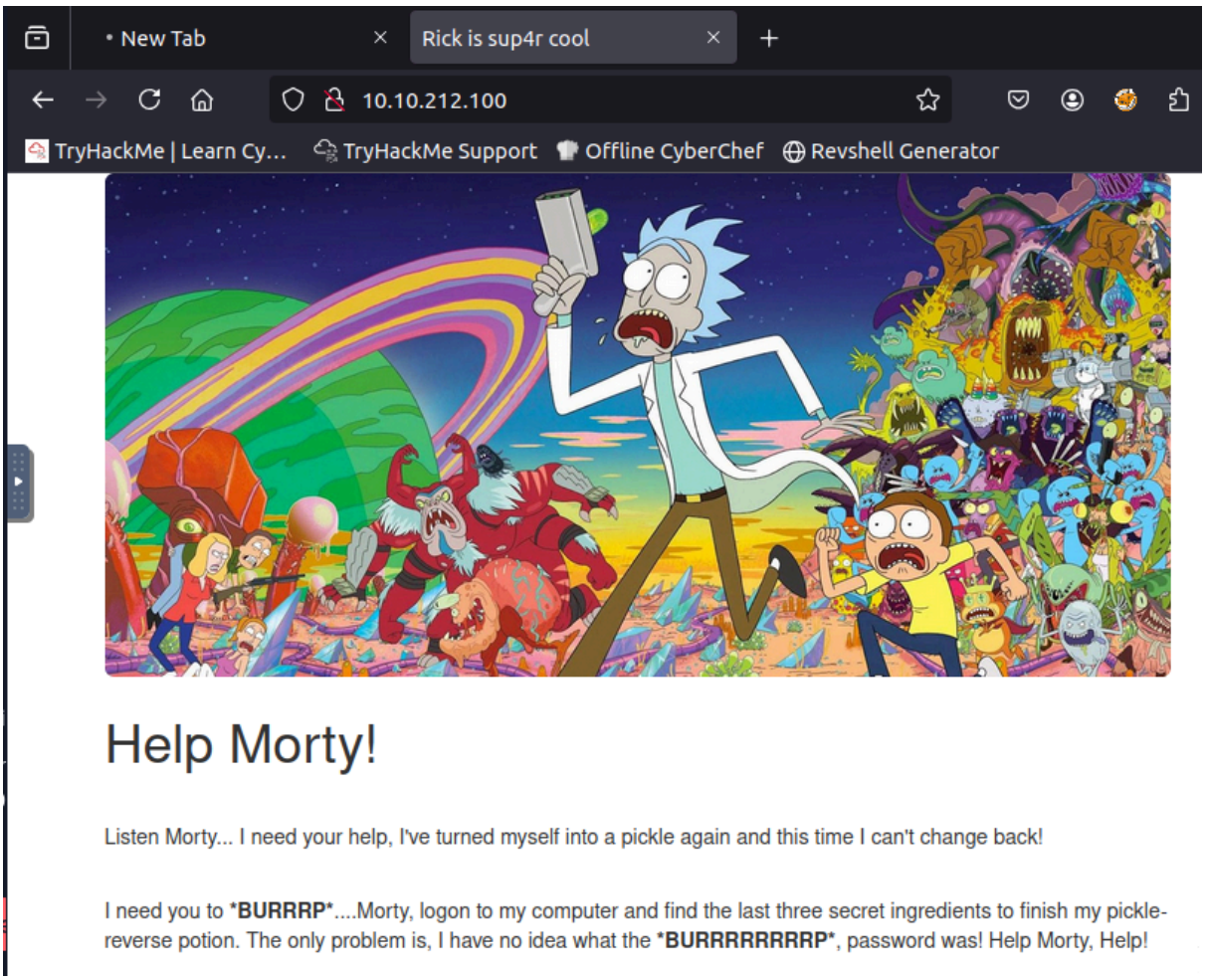
```
root@ip-10-10-142-141: ~
File  Edit  View  Search  Terminal  Help
root@ip-10-10-142-141:~# sudo nmap -sS -T5 10.10.212.100
sudo: unable to resolve host ip-10-10-142-141: Name or service not kn
own
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-21 15:26 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --syste
m-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS i
s disabled. Try using --system-dns or specify valid servers with --dn
s-servers
Nmap scan report for 10.10.212.100
Host is up (0.00019s latency).
Not shown: 998 closed ports
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 02:8A:EE:04:69:39 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.45 seconds
root@ip-10-10-142-141:~#
```

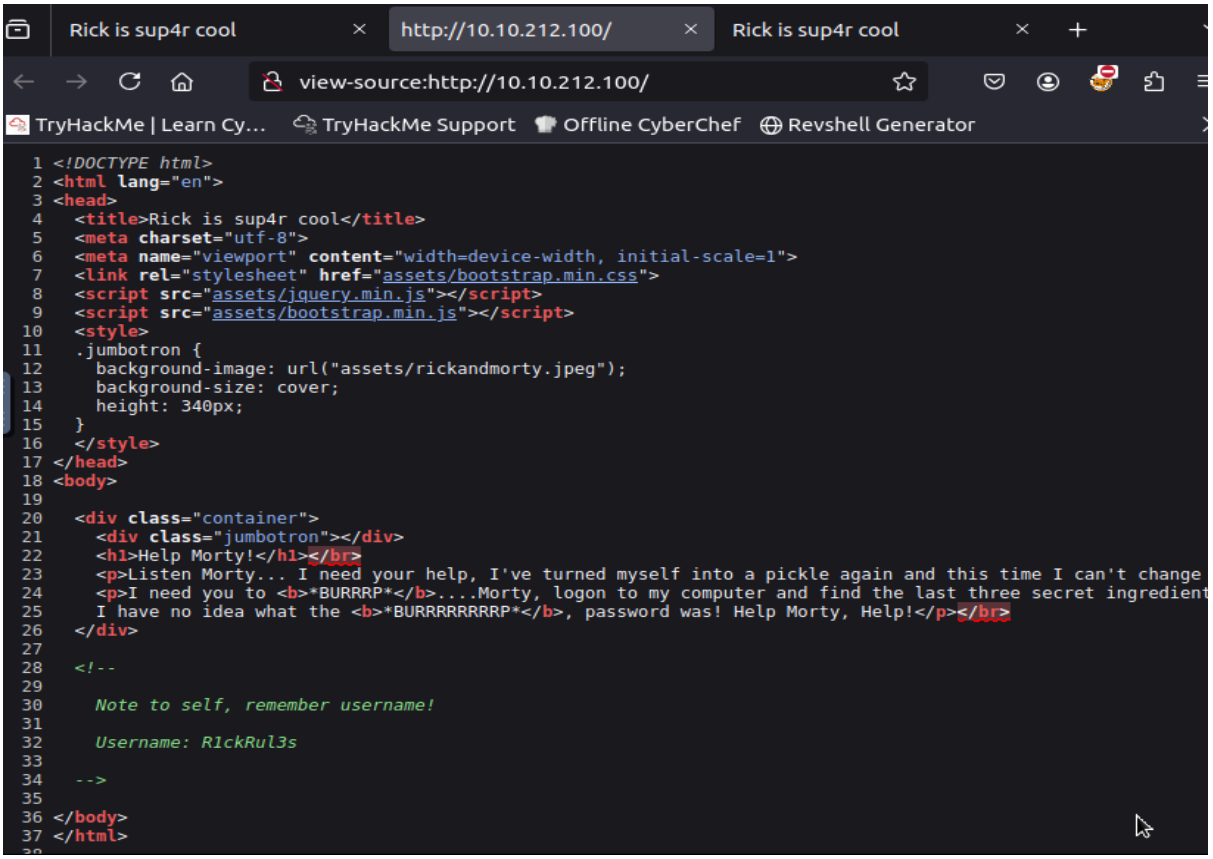
Les résultats du scan révèlent que deux ports sont ouverts sur la machine cible :

- **Port 22 (SSH)** : Ce port est habituellement utilisé pour établir une connexion sécurisée à distance. Il représente une cible potentielle pour des attaques par force brute, surtout si les identifiants utilisés sont faibles.

- **Port 80 (HTTP)** : Ce port héberge un service web. En accédant à l'URL **http://10.10.212.100/login.php**



code de la page



En analysant le code source de la page, nous avons repéré un nom d'utilisateur : **R1ckRul3s**, dissimulé dans un commentaire.

L'étape suivante consiste à identifier les répertoires et fichiers accessibles sur le serveur web hébergé à l'adresse **10.10.212.100**. Cette exploration nous permet de repérer des ressources potentiellement vulnérables ou des points d'entrée qui pourraient être exploités ultérieurement.

Pour cela, nous utilisons **Gobuster**, un outil permettant de rechercher des répertoires et fichiers sur le serveur. Voici la commande exécutée :

sudo gobuster dir -u http://10.10.212.100/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,js,py,html

- **sudo** : exécute la commande avec des privilèges administratifs

- **gobuster dir** : active le mode d'énumération de répertoires et fichiers de Gobuster

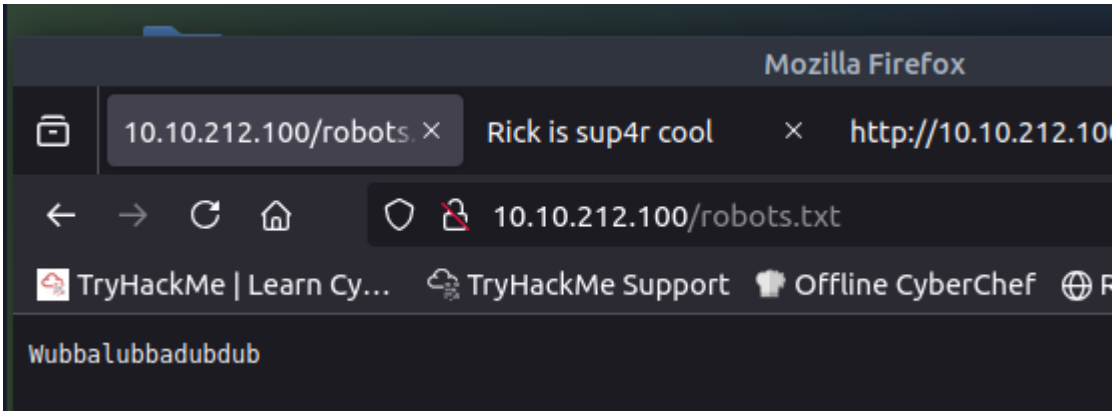
- -x php,txt,js,py,html : filtre les extensions de fichiers à rechercher, telles que php, txt, js, py, et html.
- -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt : spécifie le chemin vers la liste de mots utilisée pour l'énumération des répertoires.Cela permet de découvrir

```
root@ip-10-10-142-141:~# sudo gobuster dir -u http://10.10.212.100/ -w /usr/share
/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,js,py,html
sudo: unable to resolve host ip-10-10-142-141: Name or service not known
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.212.100/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-me
ium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,txt,js,py,html
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.php                 (Status: 403) [Size: 278]
/login.php            (Status: 200) [Size: 882]
/.html                (Status: 403) [Size: 278]
/index.html           (Status: 200) [Size: 1062]
/assets               (Status: 301) [Size: 315]
/portal.php           (Status: 302) [Size: 0]
/robots.txt           (Status: 200) [Size: 17]
```

Les trois fichiers texte identifiés semblent pertinents, car ils peuvent contenir des informations cachées ou des indices. Nous avons donc ouvert chacun de ces fichiers pour les analyser.

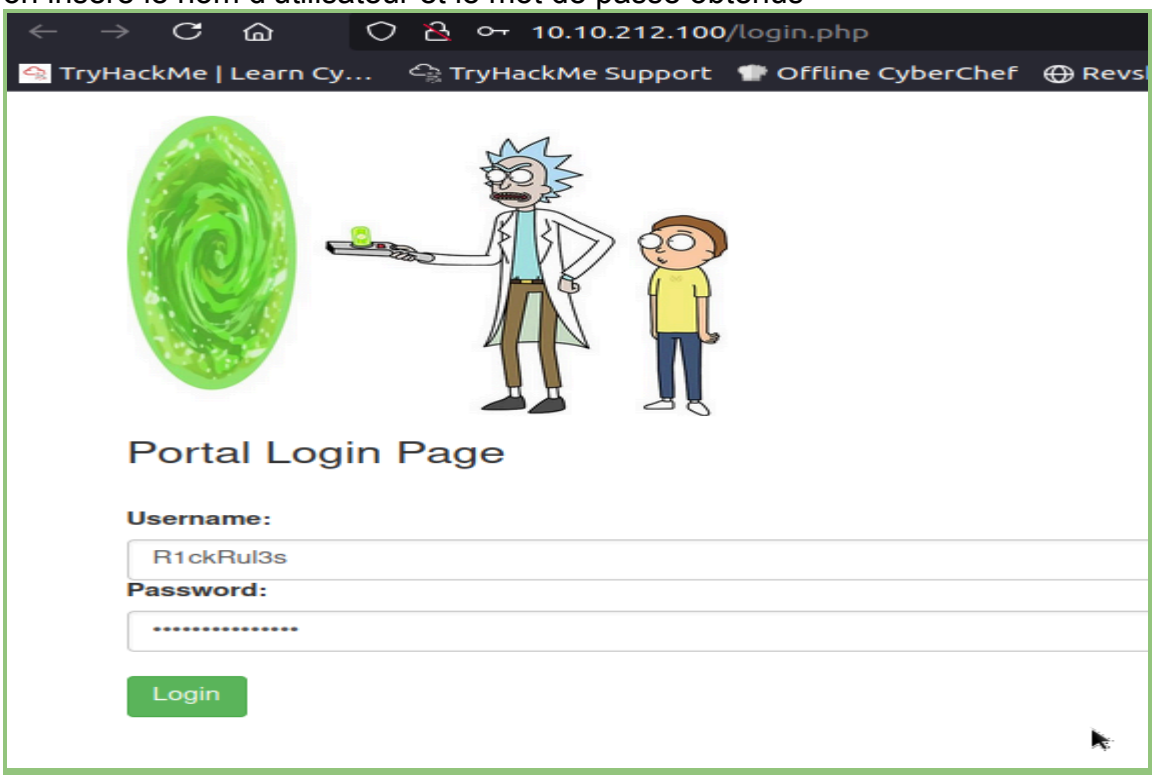
L'une des prochaines étapes consiste à accéder au fichier **robots.txt** du serveur web. Ce fichier est souvent utilisé pour indiquer les répertoires que les moteurs de recherche ne doivent pas explorer, mais il peut également contenir des informations sensibles ou des indices utiles pour avancer dans la mission, tels que des mots de passe ou des chemins d'accès cachés.

Nous avons donc utilisé l'URL suivante pour accéder à **robots.txt** :
http://10.10.212.100/robots.txt

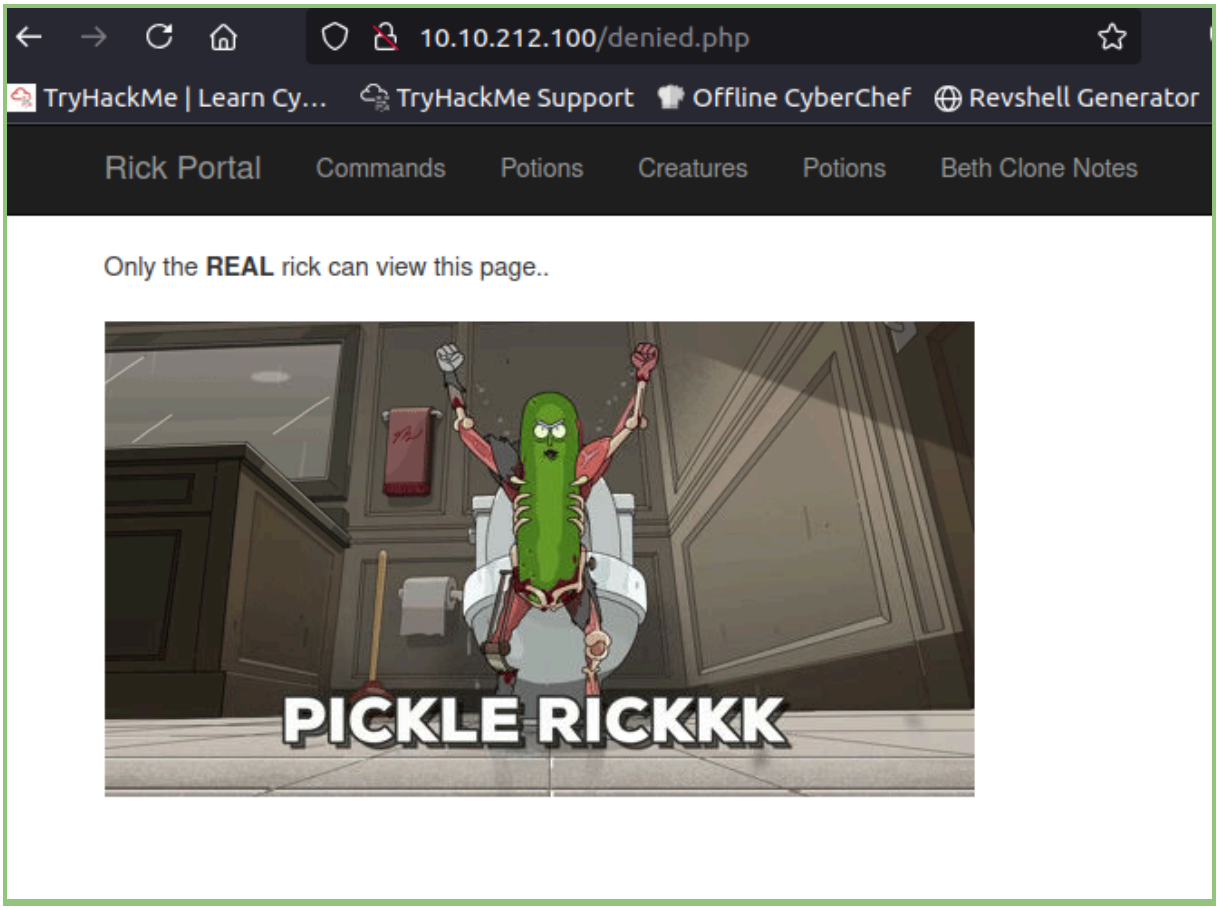


On obtient le mot de passe Wubbalubbadubdub

on insère le nom d’utilisateur et le mot de passe obtenus

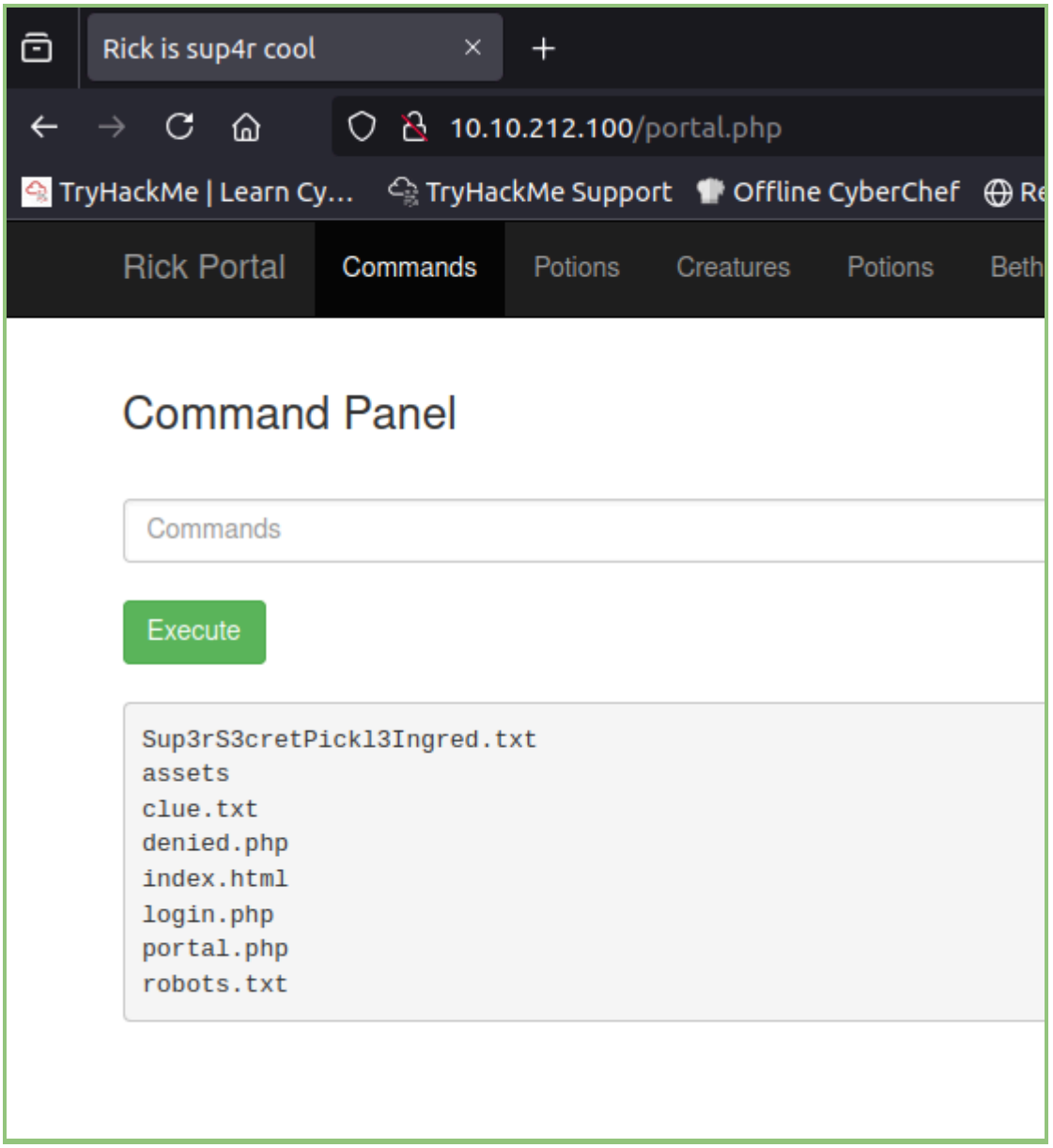


Après nous être connectés avec succès au panneau d'administration, nous avons constaté que la majorité des sections étaient verrouillées, affichant le message suivant : "Only the REAL rick can view this page." Cependant, l'onglet "Commands" était accessible. Cet onglet se présentait sous la forme d'un terminal web, offrant la possibilité d'exécuter des commandes Linux directement sur le serveur



L'interface de l'onglet **"Commands"** nous a donné la possibilité d'exécuter des commandes système sur le serveur. Pour commencer l'exploitation, nous avons utilisé la commande suivante pour lister les fichiers présents sur le serveur :ls

Cela nous a permis de voir les fichiers et répertoires accessibles dans l'environnement actuel.



Une fois la commande exécutée, une liste de fichiers et répertoires a été affichée, parmi lesquels nous avons repéré un fichier nommé **Sup3rS3cretPickl3Ingred.txt**. Le nom de ce fichier laissait penser qu'il contenait le premier ingrédient secret nécessaire à la potion de Rick.

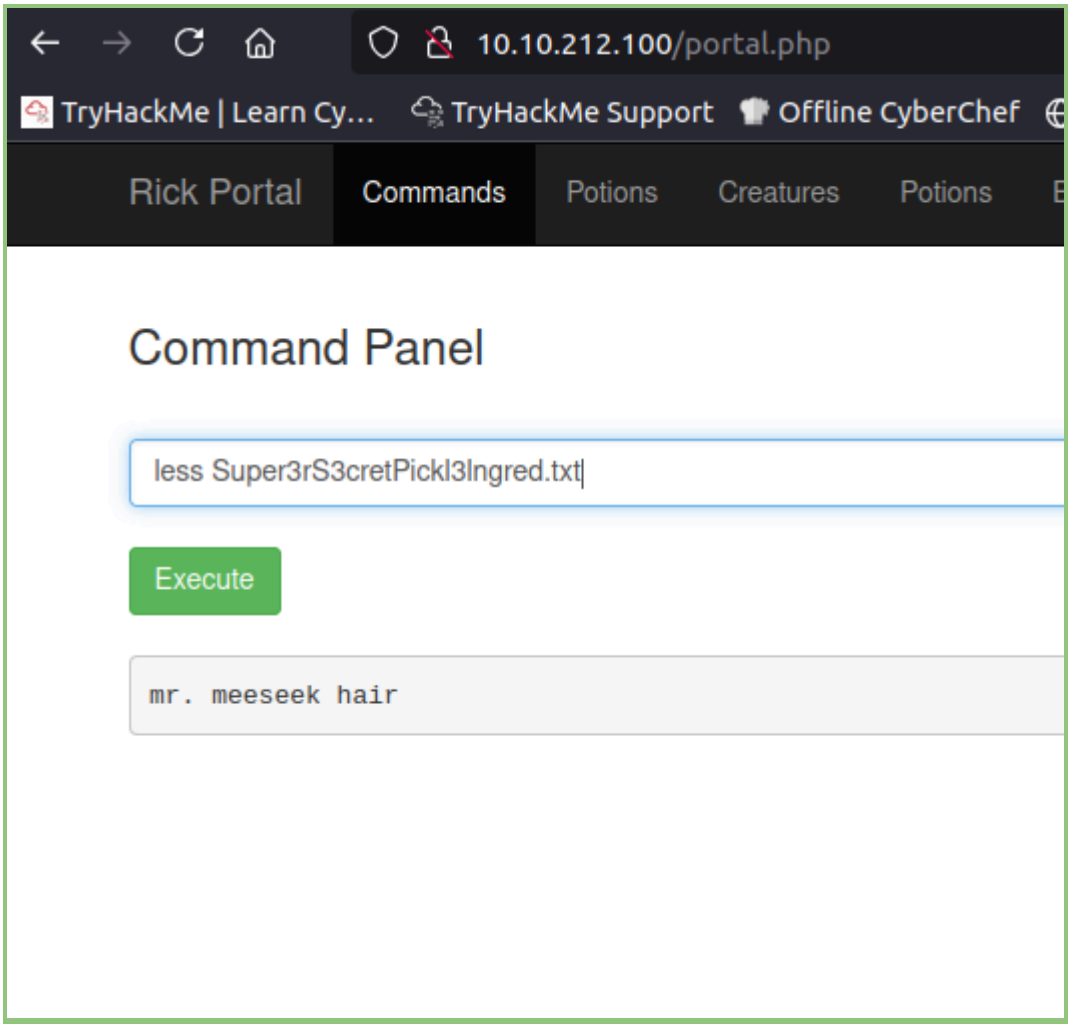
Pour vérifier le contenu de ce fichier, nous avons envisagé deux options :

- **cat** : qui permet d'afficher tout le contenu d'un fichier en une seule fois.

- **less** : qui affiche le contenu d'un fichier page par page, ce qui est particulièrement utile pour lire des fichiers de grande taille.

Bien que la commande **cat** soit généralement plus rapide, nous avons choisi **less** dans ce cas, car **cat** ne fonctionnait pas sur ce fichier.

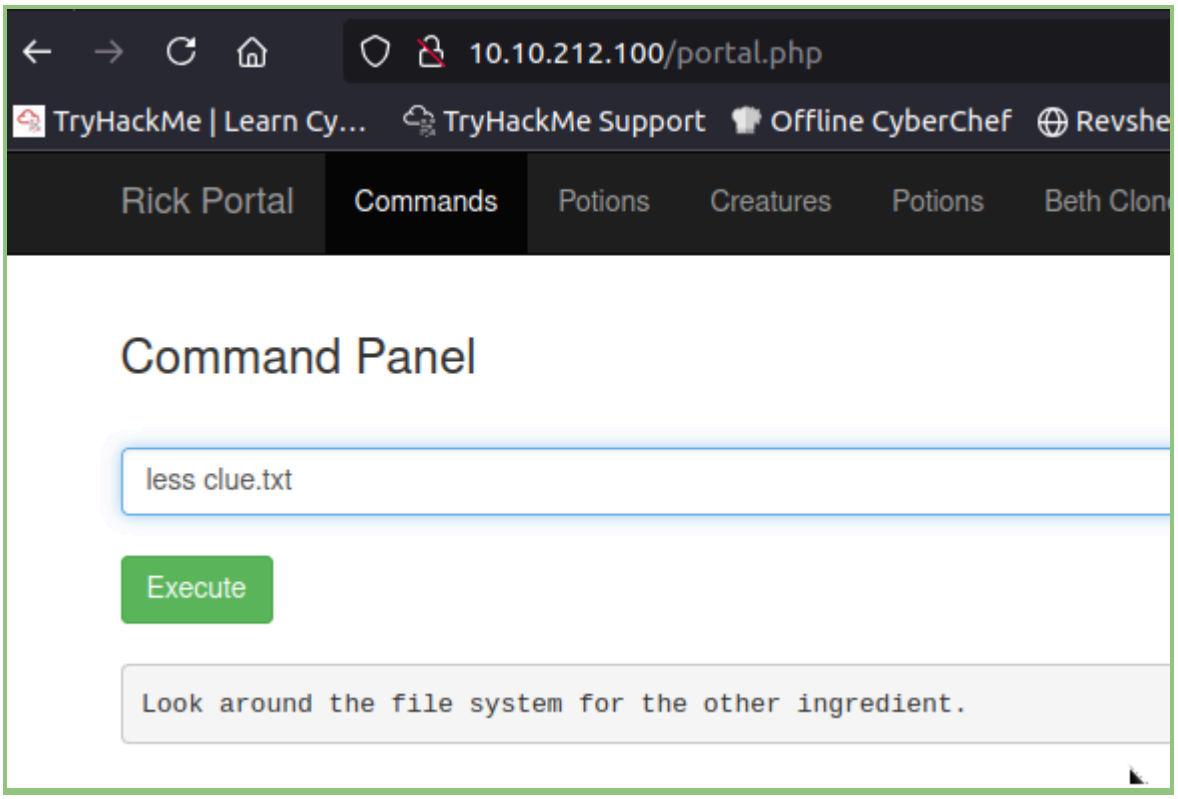
exécutons la commande suivante : **less Sup3rS3cretPickl3Ingred.txt**



En ouvrant le fichier avec la commande **less**, nous avons découvert que le premier ingrédient était: **mr.meeseek hair**

3.2 identification du deuxième ingrédient

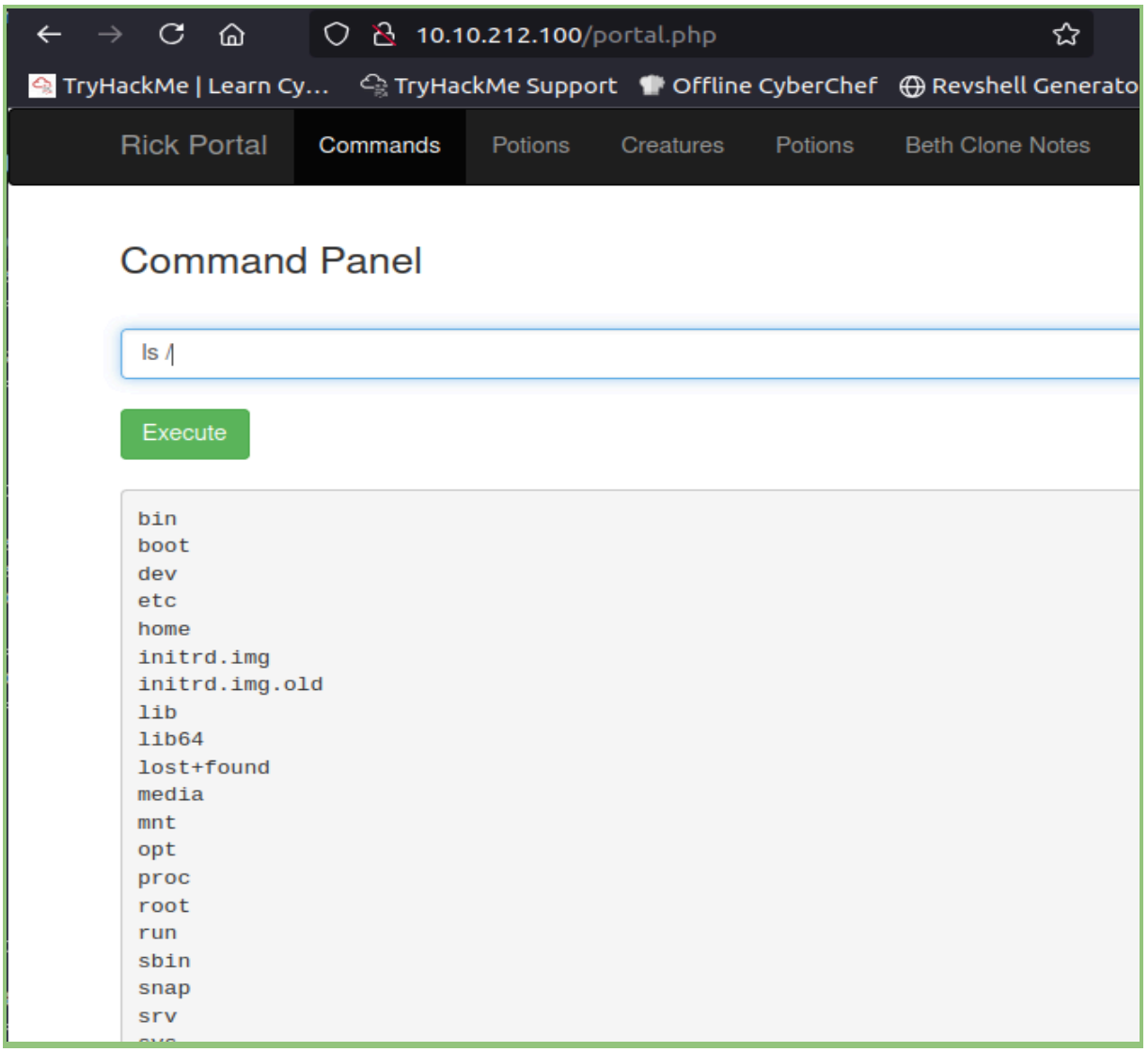
on consulte le fichier clue.txt avec la commande : **less clue.txt**



Le fichier **clue.txt** contient le message suivant : **"Look around the file system for the other ingredient."** Ce message nous guide en nous indiquant que le deuxième ingrédient ne se trouve pas dans le répertoire actuel, mais qu'il faut étendre notre recherche dans le système de fichiers.

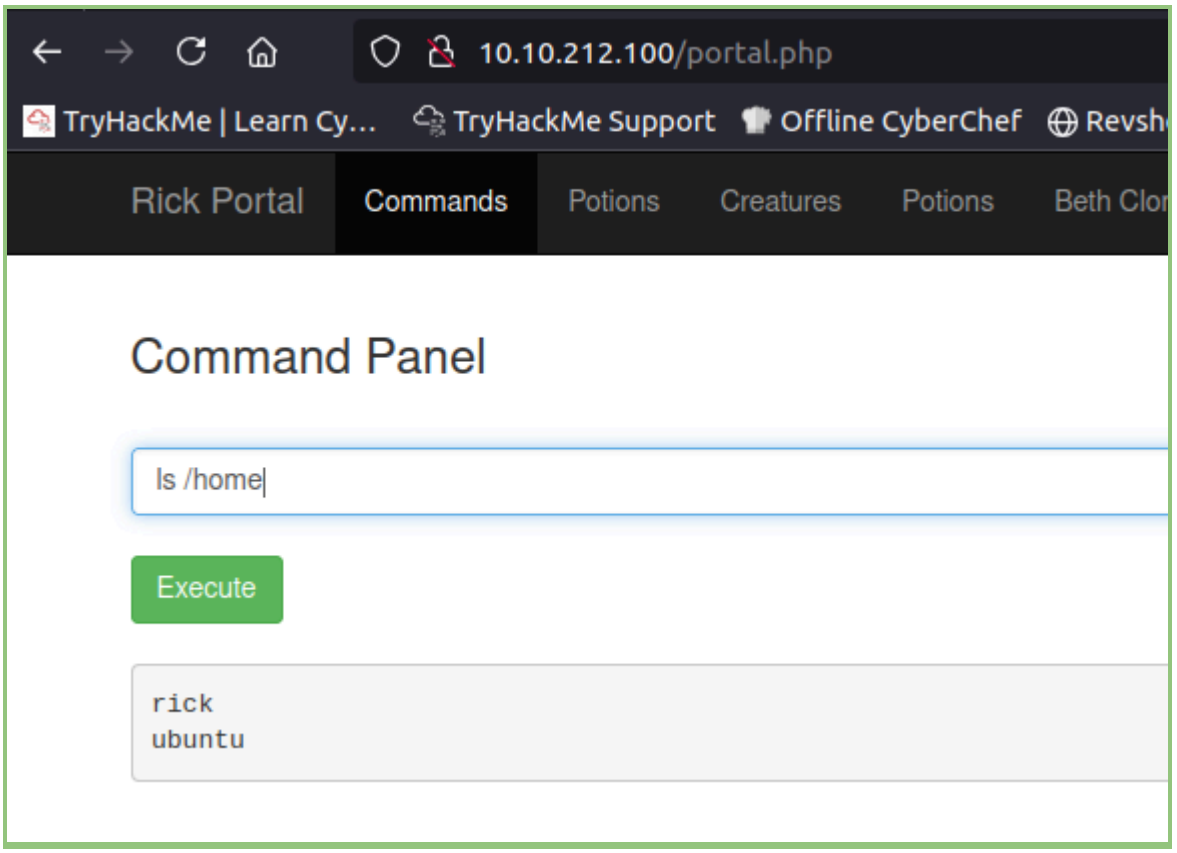
Nous avons donc décidé de nous concentrer sur le répertoire racine du système Linux (/) pour poursuivre l'exploration.
Pour ce faire, nous avons utilisé la commande suivante **: ls /**

Cette commande nous permet d'afficher le contenu du répertoire racine et d'identifier d'éventuels fichiers ou répertoires pertinents pour la suite de notre rech



Le répertoire **/home** est couramment utilisé pour stocker les dossiers personnels des utilisateurs. Nous avons donc choisi de l'explorer afin d'y trouver des informations utiles pour la suite de notre investigation.

Pour cela, nous avons exécuté la commande suivante : ls /home

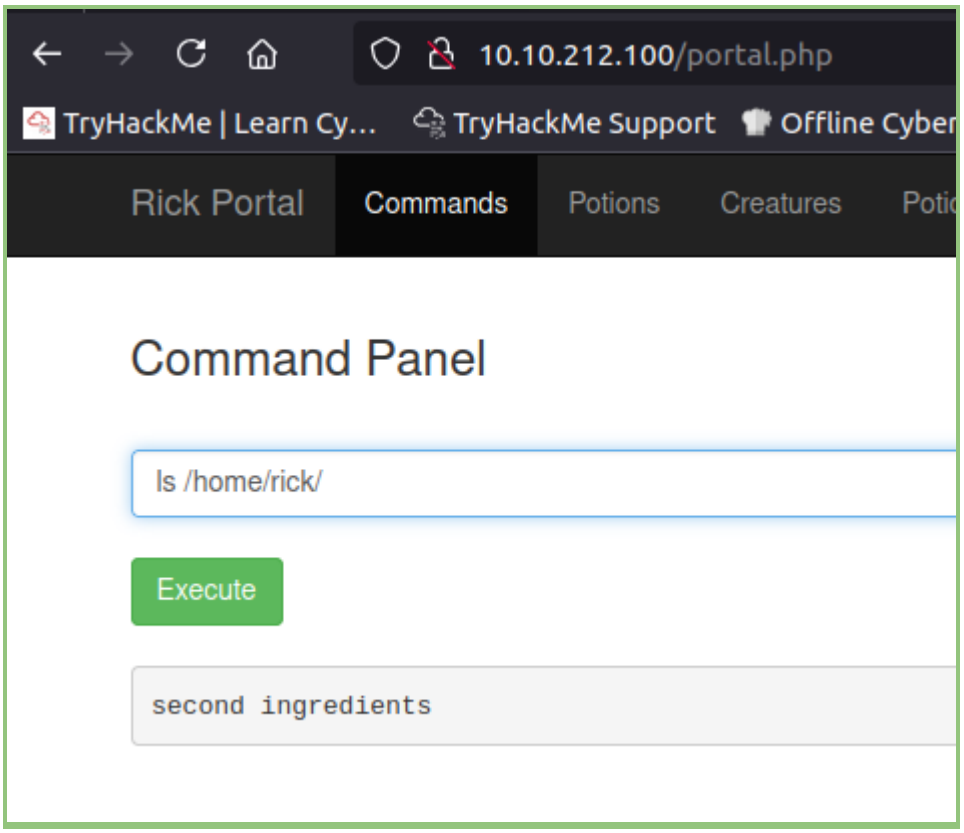


Nous avons découvert deux dossiers dans **/home** : **rick** et **ubuntu**.

Le dossier **rick** a attiré notre attention, car il semblait contenir des informations susceptibles d'être liées à Rick.

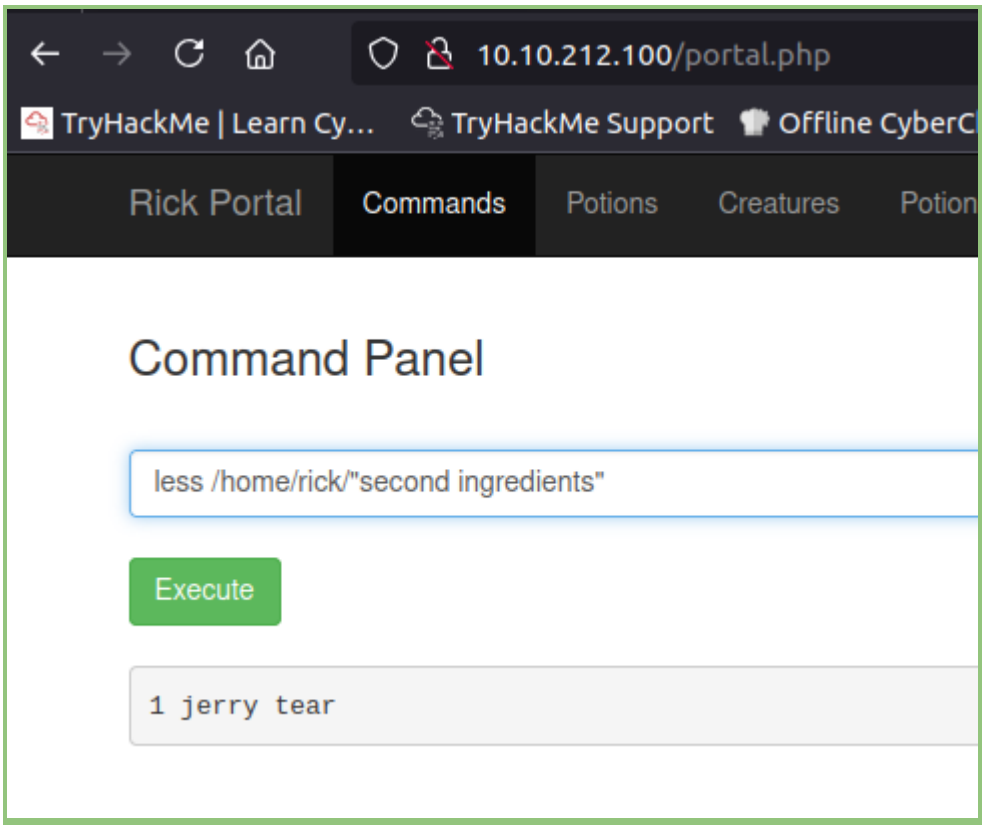
Nous avons donc décidé d'explorer ce répertoire en exécutant la commande suivante : ls /home/rick/

Cela nous a permis de lister les fichiers présents dans ce dossier et d'identifier d'éventuels indices utiles pour la suite de notre recherche



Un fichier intitulé ***second ingrédients*** a été repéré. Pour le consulter, il suffit d'utiliser la commande `less` en lui passant le chemin complet :

`less /home/rick/"second ingredient"`

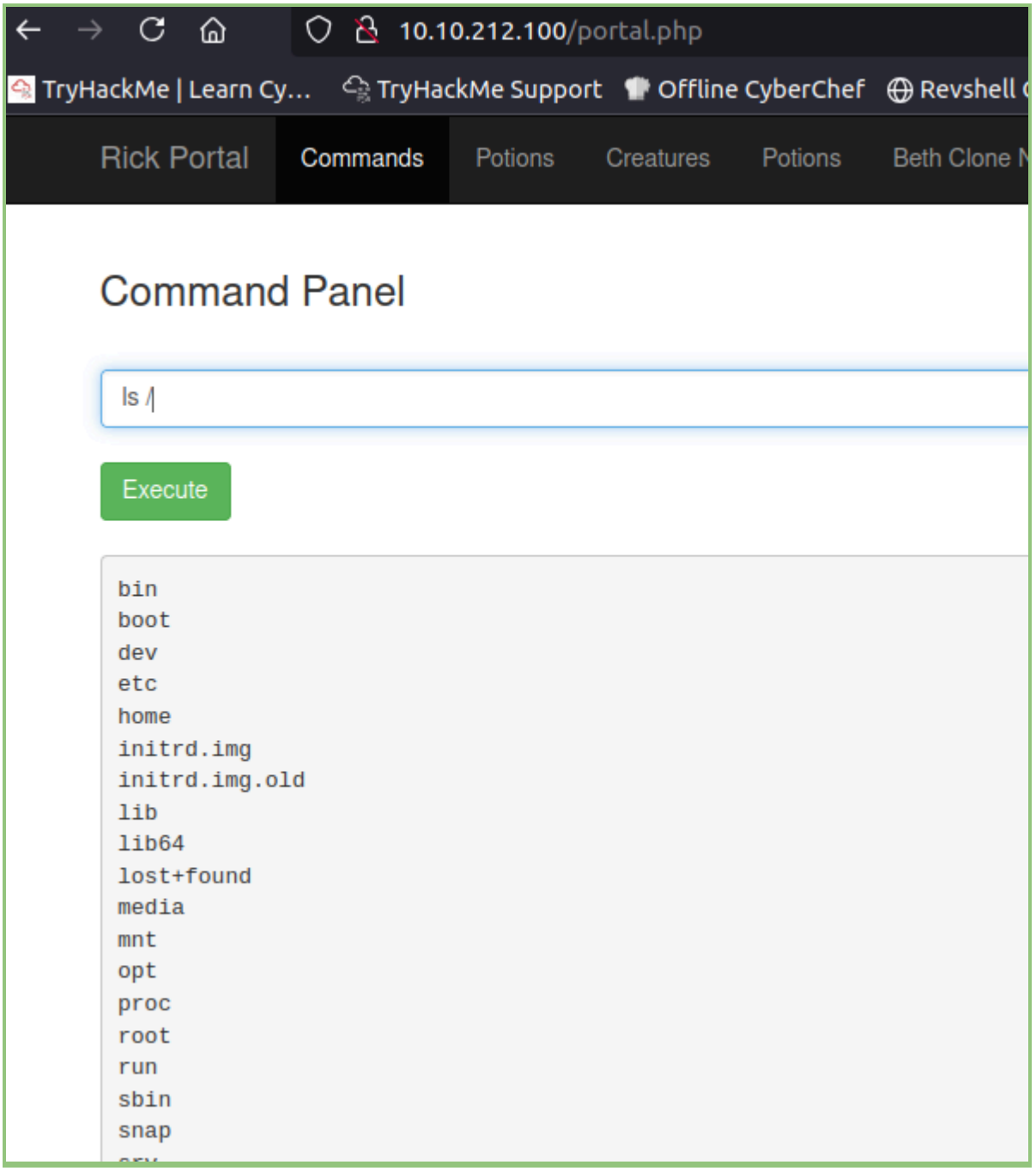


voilà le deuxième ingrédient :**1 jerry tear**

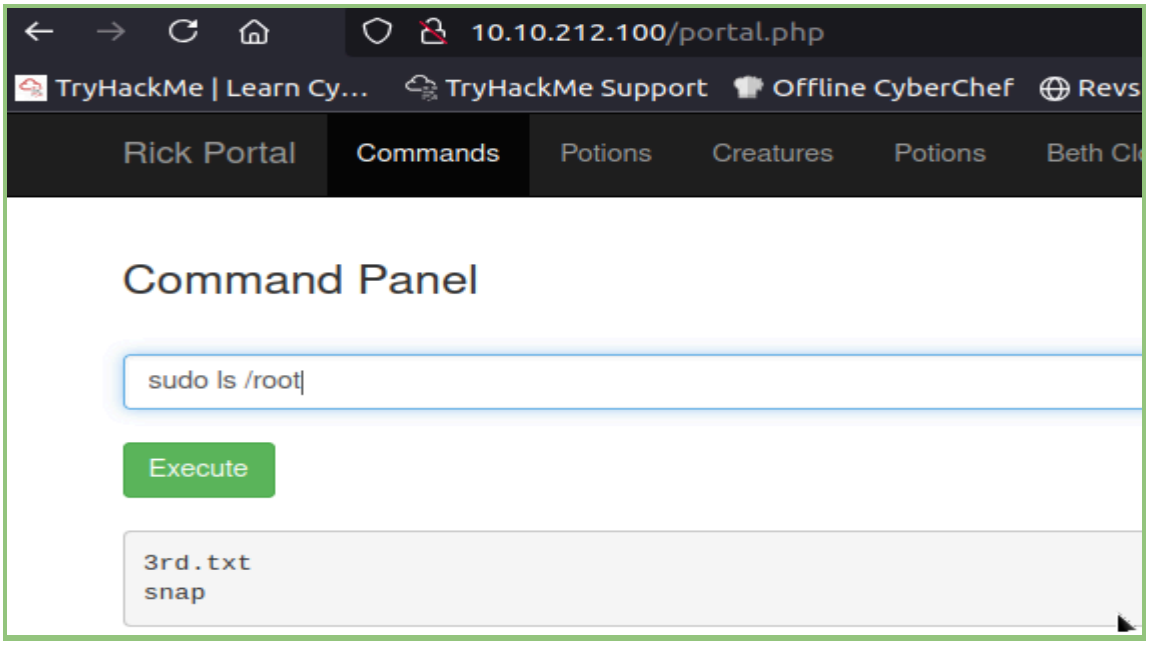
3.2 identification du dernier ingrédient

Pour obtenir le troisième ingrédient, nous avons considéré qu'il pourrait être nécessaire de disposer de droits étendus. Nous avons donc vérifié les actions que l'utilisateur actuel est autorisé à exécuter avec des privilèges élevés, notamment en consultant la liste des commandes accessibles via *sudo*

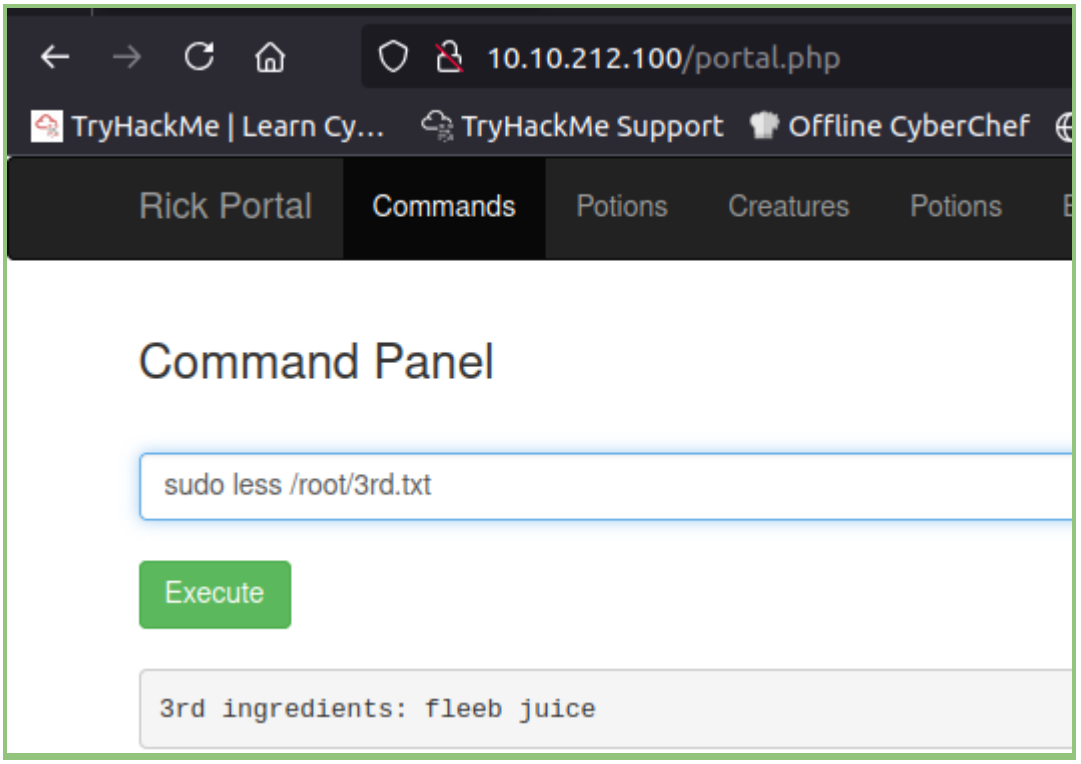
le compte *www-data* dispose de droits lui permettant d'exécuter l'ensemble des commandes avec des privilèges élevés, sans demande de mot de passe. En pratique, cela lui donne accès à des éléments du système qui seraient normalement restreints.
Après ce constat, un simple examen du contenu de la racine du système a été effectué afin d'identifier les répertoires et fichiers présents.



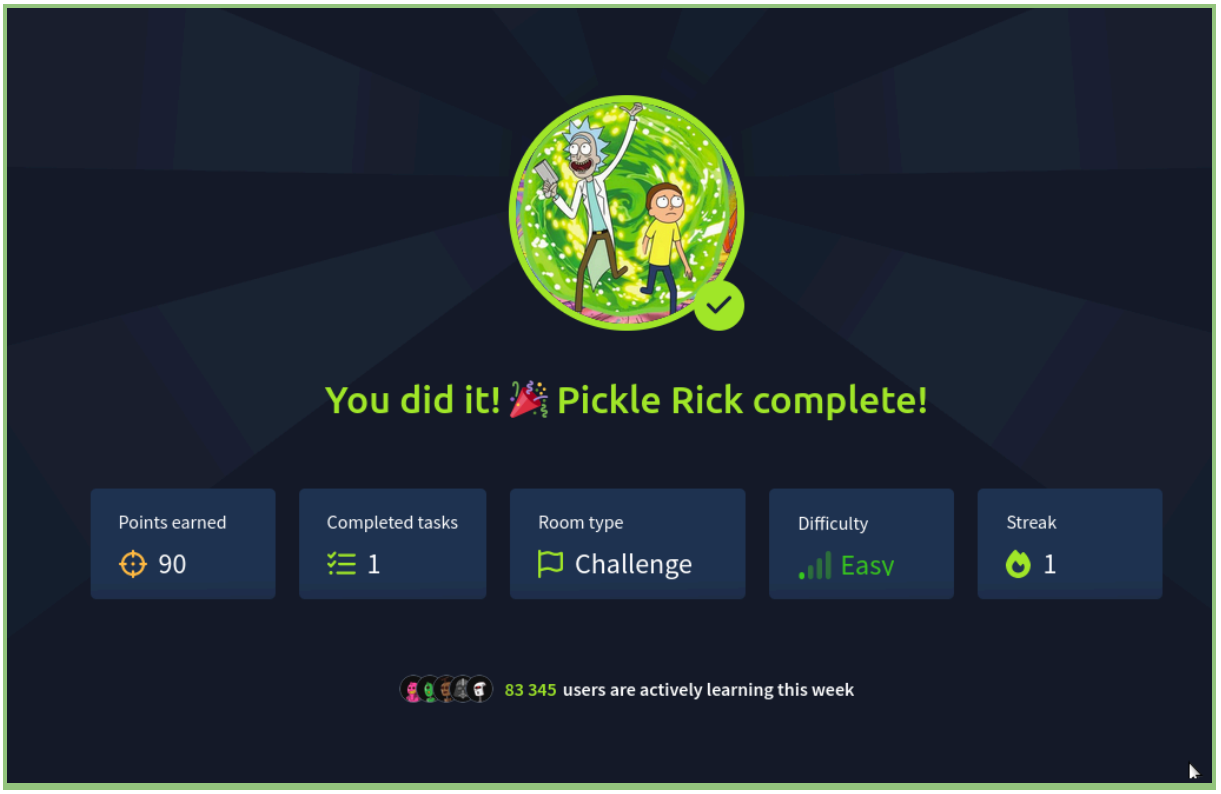
Le contenu du répertoire réservé à l'administrateur a ensuite été consulté. L'accès à cet emplacement n'étant normalement possible qu'avec des droits élevés, l'opération a été réalisée en tenant compte de ces privilèges afin d'obtenir la liste des éléments présents dans ce dossier particulier.



Pour accéder au dernier ingrédient, conservé dans le fichier *3rd.txt* situé dans l'espace réservé à l'administrateur, une consultation a été effectuée en s'appuyant sur les privilèges nécessaires. L'outil d'affichage habituel a ensuite permis de visualiser le contenu du fichier et d'en récupérer l'information finale.



Le troisième ingrédient mentionné dans le fichier est **fleeb juice**



Conclusion

L'exploration du challenge *Pickle Rick* a mis en évidence plusieurs vulnérabilités majeures, principalement liées à des configurations insuffisamment sécurisées ainsi qu'à l'utilisation d'identifiants et de mots de passe peu robustes. Ce scénario a offert l'occasion d'appliquer une démarche méthodique : analyse initiale de l'environnement, examen des ressources accessibles et étude des points faibles identifiés. Cette approche progressive a permis de comprendre comment un individu malveillant pourrait tirer parti de ces failles pour progresser dans le système.

L'exercice a démontré qu'un attaquant, même doté de compétences limitées, serait en mesure d'accéder à des informations sensibles et de compromettre la confidentialité de certains éléments. Au terme de l'investigation, trois ingrédients secrets ont pu être identifiés : ***mr. meeseek hair***, ***1 jerry tear*** et ***fleeb juice*.**

Pour renforcer la sécurité, il serait essentiel de mieux protéger les données sensibles, de revoir les paramètres de configuration exposant inutilement le système et de restreindre les privilèges accordés aux différents comptes utilisateurs.